

Risk Assessment Example

AARON MARTINEZ

CYBERSECURITY GOVERNANCE FRAMEWORK

Risk Assessment

- ▶ NIST Special Publication 800-30 - Guide for Conducting Risk Assessments
- ▶ Identify, estimate, and prioritize risk to organizational operations, organizational assets, individuals, other organizations, and the Nation, resulting from the operation and use of information systems.
- ▶ Purpose: Inform decision makers and support risk responses by identifying:
 - ▶ (i) relevant threats to organizations or threats directed through organizations against other organizations;
 - ▶ (ii) vulnerabilities both internal and external to organizations;
 - ▶ (iii) impact (i.e., harm) to organizations that may occur given the potential for threats exploiting vulnerabilities; and
 - ▶ (iv) likelihood that harm will occur.

NIST SP 800-30 Risk Assessment Process

- ▶ System Characterization
- ▶ Threat Identification
- ▶ Vulnerability Identification
- ▶ Control Analysis
- ▶ Likelihood Determination
- ▶ Impact Analysis
- ▶ Risk-level Determination
- ▶ Control Recommendations
- ▶ Results Documentation

Step 1. System Characterization

- ▶ Overall Description of the Organization & IT Department:
 - ▶ University XYZ ("the University")
 - ▶ Southern coast of Florida (FL)
 - ▶ 15,000 students
 - ▶ IT and support activities are centralized
 - ▶ IT department is the sole provider of technology and telecommunications
 - ▶ Computer processing
 - ▶ data processing
 - ▶ end-user support for systems and applications
 - ▶ training and documentation of application system controls and procedures.
 - ▶ 30 staff, under the direction of an IT Executive Director.

Step 1. System Characterization (Continued)

► Scope:

- University's financial application system
 - Banner Finance ("Banner")
 - Runs on Red Hat Enterprise Linux operating system

Application Name	Application Server Name/Operating System Version	Application Server Location
Banner	INB.xyzfl.edu/Red Hat Enterprise Linux	Computer Center, University Headquarters, FL

Step 1. System Characterization (Continued)

- ▶ Collection of Information Relevant for the Risk Assessment
- ▶ Key management personnel:
 - ▶ IT Executive Director (ITED)
 - ▶ Banner Security Administrator (BSA)
 - ▶ Operations Supervisor (OS)
 - ▶ Systems Administrator (SA)
 - ▶ Network Administrator (NA)

Step 1. System Characterization (Continued)

- ▶ Banner holds critical/sensitive information about finance, accounting, human resources, payroll.
- ▶ Users include finance, accounting, HR, and technical/IT support personnel.
- ▶ University provides networking resources to all qualified members within the university community.
- ▶ Policies and procedures are in place related to systems operations, security, and change control management.

Step 1. System Characterization (Continued)

- ▶ Users must comply with policies and guidelines, and act responsibly with network resources.
- ▶ Physical access to the facilities and data center is restricted through security mechanisms:
 - ▶ biometric devices, security guards, video surveillance, and visitor logs
- ▶ Authority to change the above physical access control mechanisms is limited to the ITED.
- ▶ Environmental controls prevent damage to computer equipment, and to protect data availability, integrity, and confidentiality:
 - ▶ fire suppression equipment, uninterruptible power supplies, alternate power generators, and raised floors

Step 1. System Characterization (Continued)

- ▶ Password settings configuration is not consistent with industry best practices.
- ▶ Reviews of user access are conducted, but not on a periodic basis.
- ▶ Terminated user accounts are removed, but not in a timely manner.
- ▶ Documentation supporting reviews and removal of user access is not maintained.
- ▶ Programmers are restricted to work in a test environment prior to implementation in production.
- ▶ Test results are not reviewed by management nor approved before final implementation in production.
- ▶ Information is backed up daily but stored locally as the University has no offsite backup storage.

Step 2. Threat Identification

► **Threat:**

- *Any circumstance or event with the potential to adversely impact organizational operations and assets, individuals, other organizations, or the Nation through an information system via unauthorized access, destruction, disclosure, or modification of information, and/or denial of service (NIST)*

► **Threat-source:**

- An intentional exploitation of a vulnerability, or an accidental trigger of a vulnerability
- Natural threats, environmental threats, and human threats.

Step 2. Threat Identification (Continued)

- ▶ **Natural threats:** hurricanes, earthquakes, and floods
- ▶ **Environmental threats:** system failures, and unexpected shutdowns
- ▶ **Human threats:** unauthorized access by hackers, terminated employees, and insiders (i.e., disgruntled, malicious, negligent, or dishonest employees)
Motivations for human threats, as identified by management, include the following:
 - ▶ Challenge, ego, and rebellion (hackers)
 - ▶ Destruction of information, illegal information disclosure, monetary gains, and unauthorized data alteration (terminated employees and hackers)
 - ▶ Curiosity, ego, intelligence, monetary gains, revenge, unintentional errors, and omissions (insiders)

Step 3. Vulnerability Identification

► Vulnerability:

- *Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited by a threat source. (NIST)*

IT Area	Vulnerability	Threat-Source
IS Operations	1. There is no offsite storage for data backups to provide reasonable assurance of availability in the event of a disaster.	Hurricanes, system failures, and unexpected shutdowns.
Information Security	2. Several of the University's password settings configured on Banner are not consistent with industry best practices.	Unauthorized users (hackers, terminated employees, and insiders).
Information Security	3. Banner application owners do not periodically review user access privileges.	Unauthorized users (hackers, terminated employees, and insiders).
Information Security	4. Terminated user accounts are not removed timely, or not removed at all, from Banner.	Unauthorized users (terminated employees).
Change Control Management	5. Test results for Banner modifications are not approved by management prior to their implementation into the production environment.	Implementation of unauthorized application modifications.

Step 4. Control Analysis

- ▶ Consider the controls that are in place or planned.
- ▶ **Goal:** reduce or eliminate the probability of a threat exercising a vulnerability.

Step 5. Likelihood Determination

- ▶ Develop a rating for the probability of vulnerabilities being exercised:
 - ▶ Motivation and capability of threat-sources
 - ▶ Nature of the vulnerability
 - ▶ Existence and effectiveness of current controls

Likelihood Level	Likelihood Definition	Likelihood-Level Value
Very High	Threat-source is extremely motivated and very capable; controls to prevent the vulnerability from being exercised are non-existent.	1.00
High	Threat-source is highly motivated and sufficiently capable; controls to prevent the vulnerability from being exercised are ineffective.	0.75
Medium	Threat-source is motivated and capable; controls exist that may prevent successful exercise of the vulnerability.	0.50
Low	Threat-source lacks motivation or capability; controls exist to prevent (or at least impede) the vulnerability from being exercised.	0.25
Very Low	There is no threat-source motivation or capability; controls in place prevent the vulnerability from being exercised.	0.10

Step 6. Impact Analysis

- Determine the magnitude of the adverse effect in the IT system resulting from threats that exercise vulnerabilities.

Magnitude of Impact	Impact Definition	Impact-Level Value
Very High	Results in the loss of extremely priced assets or resources; will violate or harm the University's reputation.	100
High	Results in the loss of highly priced tangible assets or resources; significantly violate or harm the University's reputation.	75
Medium	Results in the loss of costly tangible assets or resources; violate or harm the University's reputation.	50
Low	Results in the loss of some tangible assets or resources; noticeably affect the University's reputation.	25
Very Low	Almost no loss to tangible assets or resources; barely affects the University's reputation.	10

Step 7. Risk-Level Determination

- ▶ Determine a risk level for vulnerability/threat pairs:
 - ▶ Likelihood
 - ▶ Magnitude of impact
 - ▶ Appropriateness of planned, or existing controls
- ▶ Risk Rating = Likelihood x Impact

Risk Level	Risk Rating	Risk Description and Necessary Actions
Very High	100	Corrective measures are mandatory; action plans must be implemented; IT system may not operate.
High	75	Strong need for corrective measures; the IT system may continue to operate, but a corrective action plan must be implemented immediately.
Medium	50	Corrective actions are needed; a plan must be put in place to incorporate necessary actions within a reasonable period of time.
Low	25	Management must determine whether corrective actions are still required, or decide to accept the risk.
Very Low	10	Corrective actions may not be needed, as risks identified may be acceptable.

Step 7. Risk-Level Determination

IT Area	Vulnerability	Threat-Source	Likelihood Determination		Impact		Risk	Risk Rating
			Likelihood Level	Probability	Magnitude of Impact	Impact-Level Value		
IS Operations - Offsite Storage	1. There is no offsite storage for data backups to provide reasonable assurance of availability in the event of a disaster.	Hurricanes, system failures, and unexpected shutdowns.	Medium	0.50	High	75	1. Banner information cannot be recovered in the event of a system failure, impacting the University's ability to report financial information according to established reporting requirements.	37.5
Information Security - Passwords	2. Several of the University's password settings configured on Banner are not consistent with industry best practices.	Unauthorized users (hackers, terminated employees, and insiders).	High	0.75	High	75	2. Security parameters are not appropriately configured, allowing for potential unauthorized user access to the Banner application.	56.25
Information Security - Reviews of User Access	3. Banner application owners do not periodically review user access privileges.	Unauthorized users (hackers, terminated employees, and insiders).	Very High	1.00	High	75	3. Users possess privileges that are not consistent with their job functions, allowing unauthorized or incorrect modifications to Banner's data which could cause management decisions based upon misleading information.	75
Information Security - Terminations	4. Terminated user accounts are not removed timely, or not removed at all, from Banner.	Unauthorized users (terminated employees).	Very High	1.00	High	75	4. Terminated users can gain access to Banner and view or modify its financial information.	75
Change Control Management	5. Test results for Banner modifications are not approved by management, prior to their implementation into the production environment.	Implementation of unauthorized application modifications.	Low	0.25	High	75	5. Banner modifications are not properly authorized. Implementation of such modifications could result in invalid or misleading data.	18.75

Step 8. Control Recommendations

- ▶ Management must select a reasonable and effective cost approach to implement controls.
- ▶ **Goal:** Reduce identified risks to acceptable levels.

Option	Description
Risk Assumption	Accepts potential risks and continue on with IT operations.
Risk Avoidance	Avoids the risk by eliminating its cause and/or consequence.
Risk Limitation	Limits risks by implementing controls that minimize the impact of a vulnerability exercised by a threat.
Risk Planning	Manages risks through a risk mitigation plan that prioritizes, implements, and maintains controls.
Research and Acknowledgment	Lower risks of loss by acknowledging vulnerabilities and researching controls to correct them.
Risk Transfer	Transfers the risk to compensate for potential losses.

Step 8. Control Recommendations

- ▶ Approach for Control Recommendation/Implementation
 - ▶ Starts by prioritizing and evaluating recommended controls (RCs)
 - ▶ Followed by formal selection and identification of residual risks.
- ▶ Prioritization and Recommended Controls (RCs)
 - ▶ Process of establishing significance to the risks identified and the RCs for mitigation.
 - ▶ Based on the significance to the risks identified, control recommendations are established.

Step 8. Control Recommendations (Continued)

IT Area	Risk	Risk Level	Recommended Control (RC)	Action Priority
IS Operations - Offsite Storage	1. Banner information cannot be recovered in the event of a system failure, impacting the University's ability to report financial information according to established reporting requirements.	Medium	RC1. Backups of Banner financial data are archived off-site to minimize risk that data is lost.	Medium
Information Security - Passwords	2. Security parameters are not appropriately configured, allowing for potential unauthorized user access to the Banner application.	High	RC2. The identity of users is authenticated to Banner through passwords consistent with industry best practices minimum security values. Passwords must incorporate configuration for minimum length, periodic change, password history, lockout threshold, and complexity.	High

Step 8. Control Recommendations (Continued)

IT Area	Risk	Risk Level	Recommended Control (RC)	Action Priority
Information Security - Reviews of User Access	3. Users possess privileges that are not consistent with their job functions, allowing unauthorized or incorrect modifications to Banner's data which could cause management decisions based upon misleading information.	Very High	RC3. Banner owners authorize the nature and extent of user access privileges. RC4. The ability to make modifications to Banner security parameters, security roles, or security configuration is limited to appropriate personnel. RC5. User access privileges within Banner are periodically reviewed by application owners to verify that access privileges remain appropriate and consistent with job requirements.	Very High

Step 8. Control Recommendations (Continued)

Information Security - Terminations	4. Terminated users can gain access to Banner and view or modify its financial information.	Very High	RC6. The security administrator is notified of employees who have been terminated. Access privileges of such employees are immediately changed to reflect their new status.	Very High
Change Control Management	5. Banner modifications are not properly authorized. Implementation of such modifications could result in invalid or misleading data.	Low	RC7. Modifications to Banner are tested and approved by management prior to their implementation in production in accordance with test plans and results. RC8. User and other requests for modifications to Banner, including upgrades, fixes, and emergency changes, are documented and approved by management to verify that all changes to the production environment were documented, tested, and authorized.	Low

Step 8. Control Recommendations (Continued)

- ▶ Feasibility and Effectiveness Evaluations of Recommended Controls
- ▶ **Management Security Controls:** Manage and reduce the risk of loss while protecting the organization's mission.
 - ▶ Policies, guidelines, and standards
- ▶ **Technical Security Controls:** Relate to the configuration of parameters within applications, systems, databases, and networks.
 - ▶ Protect against security threats over critical and sensitive information, as well as IT system functions.
- ▶ **Operational Security Controls:** Make certain that security procedures governing the use of the organization's IT assets (i.e., Banner) are adequately implemented.
 - ▶ Address operational deficiencies that could result from exercised vulnerabilities.

Step 8. Control Recommendations (Continued)

IT Area: Recommended Control	Control Category and Discussion
IS Operations - Offsite Storage: RC1. Backups of Banner financial data are archived off-site to minimize risk that data is lost.	RC1 is part of the Management Security Controls and the Operational Security Controls categories. RC1 has the capability of supporting the continuity of operations and business resumption during emergencies or disasters. Equally important, RC1 ensures that Banner's backed up data gets rotated to an off-site location in order to minimize the risk that significant data could be lost during a particular event (e.g., hardware failure, computing environment disaster, etc.). The recovery of lost data could require significant effort or be virtually impossible in certain situations.
Information Security - Passwords: RC2. The identity of users is authenticated to Banner through passwords consistent with industry best practices minimum security values. Passwords must incorporate configuration for minimum length, periodic change, password history, lockout threshold, and complexity.	RC2 belongs to the Technical Security Controls category. Strong authentication controls through configuration of logical security settings (i.e., passwords) verify the identity of the employee to ensure it is valid and genuine. More important, strong password controls promote adequate security and protect Banner's financial data from threats, such as, deliberate attacks by malicious persons or disgruntled employees trying to gain unauthorized access in order to compromise system and data integrity, availability, or confidentiality. Strong passwords may also protect Banner's financial information from unintentional acts, such as negligence and errors, to circumvent system security.
Information Security - Reviews of User Access: RC3. Banner owners authorize the nature and extent of user access privileges. RC4. The ability to make modifications to Banner security parameters, security roles, or security configuration is limited to appropriate personnel. RC5. User access privileges within Banner are periodically reviewed by application owners to verify that access privileges remain appropriate and consistent with job requirements.	RC3, RC4, and RC5 pertain to the Management Security Controls as well as the Technical Security Controls categories. They make certain that access to users is granted following the principle of "least privilege" (also known as the principle of minimal privilege), which basically requires that users must be able to access only the information and resources necessary to carry on their daily tasks. In other words, access granted to users must be legitimate and consistent with job responsibilities. Failure to review user access levels on a periodic basis may not allow the University to detect and correct unauthorized access in a timely manner.

Step 8. Control Recommendations (Continued)

IT Area: Recommended Control	Control Category and Discussion
Information Security - Terminations: RC6. The security administrator is notified of employees who have been terminated. Access privileges of such employees are immediately changed to reflect their new status.	RC6 belongs to the Technical Security Controls category. Notification of employee resignations or terminations should be communicated, in a timely basis, to IT personnel and must include specific systems and/or applications so that access may be removed accurately. Failure to notify IT personnel may result in terminated employees having access rights capable of executing different types of financial transactions, exposing the University to malicious attacks, damages, intrusions, and/or misappropriation of assets. Furthermore, having active accounts of terminated employees within Banner for a period longer than necessary allows opportunities for manipulation of confidential and/or sensitive information, security breaches, etc. This may result in former employees with potential access rights for executing unlimited types of transactions (e.g., fraud accounting, disbursements, etc.).
Change Control Management: RC7. Modifications to Banner are tested and approved by management prior to their implementation in production in accordance with test plans and results. RC8. User and other requests for modifications to Banner, including upgrades, fixes, and emergency changes, are documented and approved by management to verify that all changes to the production environment were documented, tested, and authorized.	RC7 and RC8 are part of the Management Security Controls category. Change control is critical to have highly reliable systems that meet the defined service levels of the University and should be formalized through adequate documentation. It is necessary that each change be controlled throughout its life cycle and integrated into the production environment in a systematic and controlled manner. The primary objective is to maintain the integrity and reliability of the production environment, while making changes for the user community. Failure to enforce appropriate change controls can result in operational disruptions, degraded system performance, or compromised security. Furthermore, lack of documentation may result in the inability to track where changes have been made, thus, delaying the correction of problems. Proper documentation supports test results, including resolution of problems encountered, as well as approvals to implement changes into live environments.

Step 8. Control Recommendations (Continued)

- ▶ Cost–Benefit Analysis for Recommended Controls
 - ▶ **Rule 1.** If control reduces risks more than needed, consider an alternate, less expensive control.
 - ▶ **Rule 2.** If the cost of the control is higher than the risk reduction provided, consider identifying additional controls.
 - ▶ **Rule 3.** If the control does not provide a significant risk reduction, consider identifying additional controls.
 - ▶ **Rule 4.** If the control does provide a significant risk reduction and it is cost-effective, implement the control.

Step 8. Control Recommendations (Continued)

- ▶ Assess the impact of implementing versus not implementing the RC.
- ▶ Estimate the cost of implementation taking into account:
 - ▶ Additional purchases of hardware and software required.
 - ▶ Reduced operational effectiveness resulting from no implementation.
 - ▶ Reduced system performance, functionality, or security from no implementation.
 - ▶ Cost of implementing new/revised policies, procedures, standards, etc.
 - ▶ Cost of hiring (or training) personnel to implement RCs.
- ▶ Evaluate potential benefits over costs to support implementation of the new control, and communicate to senior management and Board of Directors

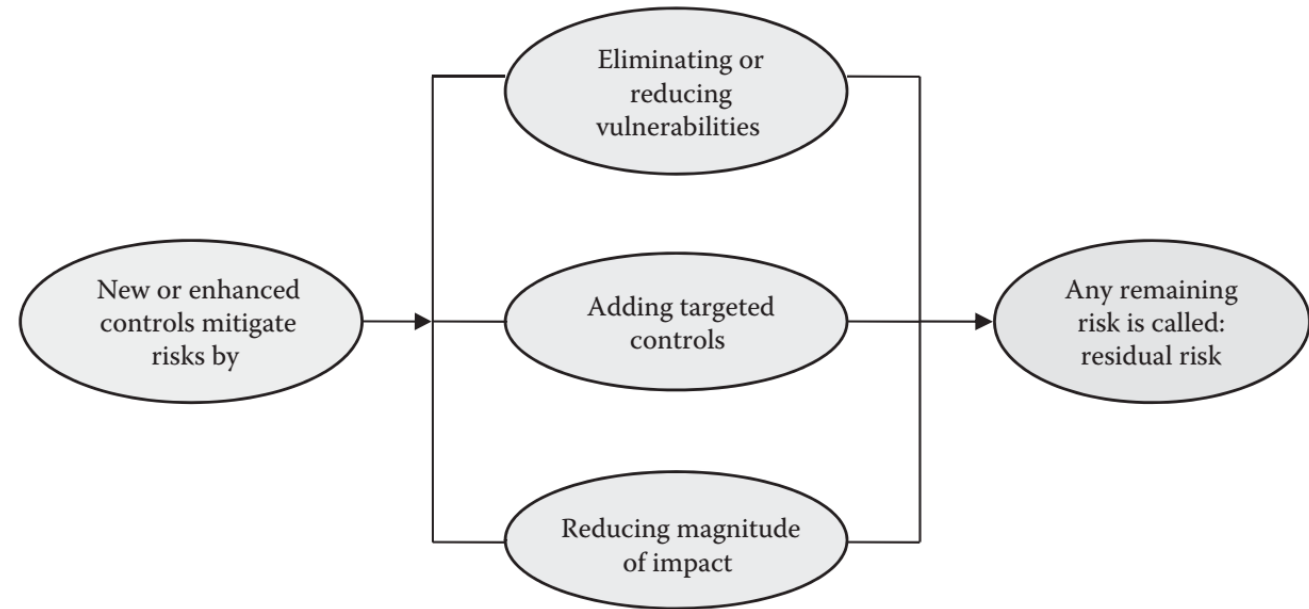
Step 8. Control Recommendations (Continued)

IT Area	Risk	Selected Control	Results/Residual Risk
IS Operations - Offsite Storage	1. Banner information cannot be recovered in the event of a system failure, impacting the University's ability to report financial information according to established reporting requirements.	RC1. Backups of Banner financial data are archived off-site to minimize risk that data is lost.	Risk reduced to acceptable levels/No residual risk.
Information Security - Passwords	2. Security parameters are not appropriately configured, allowing for potential unauthorized user access to the Banner application.	RC2. The identity of users is authenticated to Banner through passwords consistent with industry best practices minimum security values. Passwords must incorporate configuration for minimum length, periodic change, password history, lockout threshold, and complexity.	Management configured three of five security parameters (i.e., minimum length, password history, and lockout threshold). Periodic change and password complexity were not configured/Residual risks remained.
Information Security - Reviews of User Access	3. Users possess privileges that are not consistent with their job functions, allowing unauthorized or incorrect modifications to Banner's data which could cause management decisions based upon misleading information.	RC5. User access privileges within Banner are periodically reviewed by application owners to verify that access privileges remain appropriate and consistent with job requirements.	Management stated that an annual user access review within Banner would be implemented/Residual risks remained.
Information Security - Terminations	4. Terminated users can gain access to Banner and view or modify its financial information.	RC6. The security administrator is notified of employees who have been terminated. Access privileges of such employees are immediately changed to reflect their new status.	Risk reduced to acceptable levels/No residual risk.
Change Control Management	5. Banner modifications are not properly authorized. Implementation of such modifications could result in invalid or misleading data.	RC7. Modifications to Banner are tested and approved by management prior to their implementation in production in accordance with test plans and results.	Risk reduced to acceptable levels/No residual risk.

Step 8. Control Recommendations (Continued)

► Residual Risk

- Controls can mitigate or reduce risks, but cannot eliminate all risks.
- Any risk remaining after implementation is *residual risk*.



Step 9. Results Documentation

- ▶ Risk 1, Risk 4, and Risk 5 related to recovery of Banner data, access of terminated user accounts, and unauthorized implementation of Banner changes, respectively, were reduced to acceptable levels with no remaining residual risks. No further procedures were deemed necessary.
- ▶ Risk 2, related to configuration of inappropriate security parameters (i.e., passwords), as well as Risk 3 (i.e., inconsistencies in user access) was not reduced to acceptable levels resulting in some residual risks remaining

Step 9. Results Documentation

- ▶ Current password settings configured at the local area network (LAN) are consistent with industry best practices and address settings such as minimum length, password history, lockout threshold, password change, and complexity.
- ▶ Information security tools are administrated and implemented to restrict access, as well as, record and report security events
- ▶ Application owners authorize access for new users and/or users that have changed roles and responsibilities.
- ▶ Users are required to have a unique user identifier in order to distinguish one user from another and to establish accountability.
- ▶ Terminals and workstations are protected by time-out facilities, which are activated after an appropriate, predetermined period of inactivity has elapsed.

Step 9. Results Documentation

- ▶ Residual risks remained as acknowledged by management:
 - ▶ 1. Lack of reviews of user access levels
 - ▶ Risk of fraud, manipulation of information, or misappropriation and errors.
 - ▶ 2. Failure to review user access levels on a periodic basis
 - ▶ May not allow the University to detect and correct unauthorized access in a timely manner.

Step 9. Results Documentation

- ▶ Application owners authorize access for new users and/or users that have changed roles and responsibilities.
- ▶ The ability to make modifications to security parameters, security roles, or security configuration is limited to appropriate personnel.
- ▶ Information security tools are administrated and implemented to restrict access, as well as record and report security events
- ▶ There are effective procedures in place to ensure that production systems are available for the execution of processing and that financial data can be recovered should any disruptions in processing occur.
- ▶ There are effective change control procedures to ensure that Banner modifications are tested in separate test/development environment before implementation into the production environment.

Conclusion

- ▶ Management further expressed their intention to segregate Banner users in groups.
 - ▶ A schedule will be prepared to conduct additional, periodic reviews of access for several groups of users during the year.
 - ▶ Access of all these groups of users must be reviewed and approved during a period of two years.
 - ▶ Documentation supporting those reviews will also be maintained as evidence.
- ▶ Control activities help with managing and mitigating the residual risks resulting from password settings, as well as the lack of periodic user access reviews.
- ▶ These additional safeguards compensate the exceptions previously noted and can mitigate the risks of unauthorized users gaining access to Banner financial data.

Q&A

► Questions?

References

- ▶ NIST. (2012). Guide for Conducting Risk Assessments. Special Publication 800-30 Revision 1. Retrieved from <https://csrc.nist.gov/publications/detail/sp/800-30/rev-1/final>
- ▶ Otero, A. R. (2019). Information Technology Control and Audit (5th ed.). Boca Raton, FL, US: Taylor & Francis Group.